

Mapeo de Preguntas a Requisitos Normativos ENS / CCN-STIC

Nota: Este mapeo es orientativo y se basa en la alineación conceptual con ENS (RD 311/2022) y guías CCN-STIC-815 (métricas) y 824 (informe de estado), así como con el uso de INES/AMPARO. [web:30] [web:32][web:33][web:21][web:39]

Código pregunta	Bloque / Pregunta (resumen)	Referencias ENS / CCN-STIC principales	Comentario de alineación
0.1	Tipo de entidad	ENS art. 2; RD 311/2022 ámbito subjetivo [web:30]	Determina la aplicabilidad y obligaciones concretas respecto al ENS y al Informe INES.
0.5	Certificación ENS actual	ENS art. 36 (declaración de conformidad y certificación); CCN-STIC-808	Identifica el grado de formalización de la adecuación ENS y su verificación externa.
1.1.1	Política de seguridad aprobada por dirección	ENS Anexo II medidas organizativas; art. 11 [web:30]	Evalúa la existencia de una política formal, requisito básico de gobernanza.
1.1.3	Comité de Seguridad de la Información	ENS Anexo II (organización de la seguridad) [web:30]	Refleja la existencia de órganos de gobierno y coordinación en materia de seguridad.
1.2.1	Cumplimentación Informe INES	ENS art. 12 (informe de estado); CCN-STIC-824; Plataforma INES [web:21][web:33] [web:39]	Mide el grado de cumplimiento de la obligación de informar y de alimentar el Informe Nacional.
1.2.2	Uso de AMPARO para gobernanza ENS	Herramientas de gobernanza CCN (INES/AMPARO) [web:21][web:39]	Evalúa la integración de AMPARO en la gestión documental y de planes de adecuación ENS.
1.2.3	Declaración de Aplicabilidad (DA)	ENS Anexo II; CCN-STIC-808/881 (auditoría y adecuación) [web:28] [web:23]	La DA es una pieza clave en la verificación de medidas ENS; esta pregunta mide su existencia y actualización.
1.3.1	Porcentaje de medidas ENS implantadas	ENS Anexo II; CCN-STIC-815 (métricas de cumplimiento) [web:32][web:35]	Relacionada con indicadores de cobertura de medidas definidos en CCN-STIC-815.
1.3.3	Identificación y categorización de sistemas ENS	ENS art. 10 (categorías de sistemas); Anexo I [web:30]	Fundamental para determinar el nivel de exigencia de medidas y el alcance de la certificación.

2.1.1	Metodología de análisis de riesgos	ENS art. 35 (evaluación de seguridad); MAGERIT / PILAR [web:30][web:38]	Evalúa la adopción de metodologías reconocidas para análisis de riesgo, coherente con ENS y CCN-STIC.
2.1.2	Frecuencia del análisis de riesgos	ENS art. 35; CCN-STIC-815 (métricas de periodicidad) [web:32] [web:35]	Mide la regularidad con la que se actualizan los análisis requeridos por ENS.
2.2.2	Uso de autenticación multifactor (MFA)	ENS Anexo II (control de acceso); guías CCN-STIC específicas	Indicador alineado con medidas de protección de acceso, reforzado por marcos Zero Trust.
2.2.3	Segmentación y microsegmentación	ENS Anexo II (protección de redes y sistemas)	Refleja la implantación de controles de segmentación asociados a modelos de defensa en profundidad y Zero Trust.
2.3.1/2.3.2	Cifrado en tránsito y en reposo	ENS Anexo II (protección de la información); guías criptográficas CCN	Evalúa la implantación de medidas criptográficas, parte nuclear de ENS y de buenas prácticas internacionales.
2.3.3	Análisis de riesgo criptográfico y post-cuántico	ENS art. 35; marcos de riesgo emergente [web:12][web:3]	Introduce dimensión de amenazas avanzadas, alineada con análisis de riesgo extendido.
3.1.1	Procedimiento de gestión de incidentes	ENS Anexo II (gestión de incidentes); CCN-STIC-817 [web:25]	Verifica la existencia de procesos de gestión de incidentes conforme a ENS.
3.1.3	Cálculo de MTTD y MTTR	CCN-STIC-815 (indicadores de eficacia); CCN-STIC-824 [web:32] [web:33]	Mide el uso de indicadores de eficacia operativa, recomendados en las guías de métricas.
3.2.1	Cobertura de monitorización (SIEM/SOC)	ENS Anexo II (monitorización); op.mon.2 (sistema de métricas) [web:32] [web:35]	Vinculado al requisito ENS de disponer de monitorización y métricas de seguridad.

3.2.3	Simulacros y ejercicios de incidentes	ENS Anexo II (continuidad y pruebas); CCN-STIC-824 [web:33]	Relacionado con la obligación de ejercitar y evaluar la capacidad de respuesta.
3.3.1	BCP/DRP con ciberincidentes	ENS Anexo II (continuidad de la actividad); art. 27 [web:30]	Pregunta clave sobre integración de la seguridad en la continuidad de negocio.
4.1.1	Porcentaje de presupuesto destinado a ciberseguridad	CCN-STIC-815 (métricas de recursos); informes de situación de ciberseguridad [web:8][web:13] [web:32]	Relacionado con métricas de esfuerzo inversor en seguridad.
4.2.1	Programas de formación en ciberseguridad	ENS Anexo II (capacitación y concienciación) [web:30]	Evalúa el cumplimiento de medidas de concienciación exigidas por ENS.
4.2.2	Campañas de concienciación y simulaciones de phishing	CCN-STIC-815 (métricas de cultura); informes industriales [web:8][web:13] [web:32]	Indicadores de madurez de cultura de seguridad.
5.1.1	Existencia de cuadro de mando de ciberseguridad	CCN-STIC-815 (sistema de métricas e indicadores) [web:32] [web:35]	Pregunta central sobre institucionalización de la medición de la seguridad.
5.1.3	Uso de CCN-STIC-815 y 824 como referencia	CCN-STIC-815 y 824 [web:32][web:33]	Verifica el alineamiento con las guías oficiales de métricas e informe de estado.
5.2.1	Uso de INES/AMPARO para priorizar inversiones	ENS art. 12; INES como herramienta de indicadores [web:21] [web:39]	Mide el grado en que la métrica ENS se utiliza para la planificación estratégica y presupuestaria.
5.2.2	Definición de modelos de ROI en ciberseguridad	CCN-STIC-815 (métricas de eficiencia y coste) [web:32] [web:35]	Relacionado con la evaluación de la eficiencia de las medidas de seguridad.

6.1/6.2	Prioridades estratégicas y barreras	ENS art. 35; CCN-STIC-824 (identificación de áreas de mejora) [web:33]	Preguntas abiertas que permiten contextualizar las necesidades de mejora identificadas en ENS y el sistema de indicadores.
----------------	--	---	--

El mapeo completo a nivel de cada ítem puede ampliarse añadiendo una fila por pregunta, con el código interno utilizado en el Excel y referencias a otros marcos (ISO 27001, NIST CSF, NIS2) para análisis comparados.